Nama : Riri Fauzia Haris

Nim : 24250007

Prodi : Sistem Informasi

Aplikasi Berbasis Service

ISO/IEC 27001 — Information Security Management

A. Pengertian

ISO/IEC 27001 adalah standar internasional yang berisi persyaratan untuk membangun, menjalankan, memelihara, dan terus memperbaiki Sistem Manajemen Keamanan Informasi (SMKI/ISMS) di sebuah organisasi.

Sederhananya, standar ini adalah "panduan resmi" agar organisasi punya cara yang terstruktur dalam menjaga keamanan informasinya, bukan hanya mengandalkan antivirus atau firewall. Standar ini diterbitkan oleh ISO dan IEC. Versi terbaru adalah ISO/IEC 27001:2022 (ditambah *Amendment 1:2024* tentang pertimbangan perubahan iklim).

B. Tujuan: Prinsip CIA Triad

1. Confidentiality (Kerahasiaan)
   informasi hanya boleh dilihat oleh orang yang berhak. Contoh : data nilai mahasiswa hanya bisa dibuka oleh mahasiswa terkait dan pihak akademik
2. Integrity (Integritas)
   informasi harus benar, utuh, dan tidak diubah sembarangan. Contoh: nilai di sistem tidak boleh berubah tanpa izin.
3. Availability (Ketersediaan)
   informasi dan layanan dapat diakses saat dibutuhkan. Contoh: sistem KRS tetap bisa dibuka saat masa pengisian.

C. Struktur Klausul (Klausul 4–10)

Klausul adalah bagian-bagian persyaratan yang wajib dipenuhi organisasi.

1. Klausul 4 (Context of the Organization)

   Organisasi memahami kondisi internal dan eksternalnya, siapa saja pihak yang berkepentingan, serta menentukan batas (ruang lingkup) ISMS.
2. Klausul 5 (Leadership)

   Oimpinan harus berkomitmen, menetapkan kebijakan keamanan informasi, dan membagi peran serta tanggung jawab.
3. Klausul 6 (Planning)

   Organisasi merencanakan langkah dengan mengenali risiko dan peluang, lalu menentukan cara menanganinya.
4. Klausul 7 (Support)

   Organisasi menyediakan dukungan, seperti sumber daya, SDM yang kompeten, kesadaran keamanan, komunikasi, dan dokumentasi.
5. Klausul 8 (Operation)

   Rencana yang sudah dibuat dijalankan, termasuk penilaian dan penanganan risiko secara rutin
6. Klausul 9 (Performance Evaluation)

   Hasil penerapan dipantau dan dievaluasi melalui pengukuran, audit internal, dan tinjauan manajemen.
7. Klausul 10 (Improvement)

   Jika ada ketidaksesuaian atau insiden, organisasi memperbaikinya dan terus meningkatkan sistem.

D. Annex A (Kontrol Keamanan)

Annex A adalah daftar kontrol (tindakan pengamanan) yang dapat dipilih organisasi untuk menangani risiko. Versi 2022 memiliki 93 kontrol (sebelumnya 114 kontrol pada versi 2013) yang dibagi menjadi 4 tema :

1. Organizational Controls (37 kontrol)

   Aturan dan kebijakan organisasi, seperti kebijakan keamanan, pengelolaan aset, dan hubungan dengan pemasok.

2. People Controls (8 kontrol)

   Hal yang berkaitan dengan manusia, seperti seleksi pegawai, pelatihan kesadaran keamanan, dan perjanjian kerahasiaan.
3. Physical Controls (14 kontrol)

   Pengamanan fisik, seperti kontrol akses ruang server, CCTV, dan perlindungan perangkat.
4. Technological Controls (34 kontrol)

   Pengamanan teknis, seperti enkripsi, kontrol akses sistem, pencatatan log, dan backup.

E. Siklus PDCA

Siklus PDCA (*Plan-Do-Check-Act*) adalah metode perbaikan berkelanjutan yang dilakukan secara berulang melalui empat tahap : merencanakan, menjalankan, memeriksa, dan memperbaiki. Dalam ISO/IEC 27001, siklus ini digunakan agar keamanan informasi terus dievaluasi dan ditingkatkan.

1. Plan (Rencanakan)

   Menentukan ruang lingkup, kebijakan, dan menilai risiko.
2. Do (Jalankan)

   Menerapkan kontrol dan rencana penanganan risiko.
3. Check (Periksa)

   Memantau, mengukur, dan mengaudit hasilnya.
4. Act (Perbaiki)

   Memperbaiki kekurangan agar sistem makin baik.

Siklus ini berulang terus, sehingga keamanan tidak berhenti setelah sertifikasi didapat.

F. Keterkaitan dengan SOA

ISO/IEC 27001 bukan standar khusus SOA, tetapi dapat menjadi kerangka tata kelola keamanan bagi sistem berbasis layanan. Pada SOA, aplikasi dipecah menjadi banyak layanan yang saling bertukar data melalui jaringan. Setiap titik komunikasi bisa menjadi celah serangan, sehingga risikonya lebih luas dibanding sistem monolitik (satu aplikasi utuh).

Aspek SOA	Penerapan Kontrol ISO 27001	Penjelasan Sederhana
Autentikasi dan otorisasi layanan	Access control dan manajemen identitas (SAML, OAuth 2.0, WS-Security)	Memastikan hanya pengguna atau layanan yang sah yang dapat memanggil sebuah layanan.
Pertukaran data antarlayanan	Kriptografi dan keamanan jaringan (TLS, XML Encryption/Signature)	Data diacak saat dikirim agar tidak bisa dibaca atau diubah pihak lain di tengah jalan.
Kontrak layanan (SLA)	Keamanan dalam hubungan dengan pemasok dan pihak ketiga	Kewajiban keamanan dan tingkat layanan disepakati secara tertulis.
Pemantauan layanan	Logging, monitoring, dan manajemen insiden	Aktivitas layanan dicatat agar serangan atau gangguan cepat terdeteksi.

G. Manfaat

1. Melindungi aset informasi dan layanan : ancaman dikenali dan ditangani sejak awal.
2. Meningkatkan kepercayaan : pelanggan dan mitra lebih yakin karena organisasi memiliki sertifikasi yang diakui internasional.
3. Mendukung kepatuhan regulasi : membantu memenuhi aturan seperti UU Pelindungan Data Pribadi (UU PDP).
4. Mengurangi dampak insiden : organisasi sudah punya prosedur penanganan, sehingga kerugian dapat ditekan.
5. Dapat disertifikasi : organisasi dapat diaudit dan disertifikasi oleh lembaga sertifikasi terakreditasi.

H. Tantangan

1. Butuh komitmen dan sumber daya besar : penerapan memerlukan dukungan pimpinan, waktu, dan biaya.
2. Dokumentasi dan audit berkala : banyak dokumen harus disusun dan diperbarui secara rutin.

3. Kompleksitas pada sistem terdistribusi : mengamankan banyak layanan yang saling terhubung lebih rumit daripada satu sistem tunggal.

I. Kesimpulan

ISO/IEC 27001 menyediakan kerangka yang sistematis, berbasis manajemen risiko, untuk menjaga kerahasiaan, integritas, dan ketersediaan informasi. Dalam konteks SOA, standar ini membantu memastikan layanan-layanan yang saling terhubung tetap aman, andal, dan dikelola secara berkelanjutan.

Referensi

1. ISO/IEC 27001:2022, *Information security, cybersecurity and privacy protection — Information security management systems — Requirements*.
2. ISO/IEC 27002:2022, *Information security, cybersecurity and privacy protection — Information security controls*.
3. Situs resmi ISO: iso.org/standard/27001